

Step 05 — Audit foundation (manual test guide)

Goal: Confirm create/update/delete actions write immutable audit entries (actor, action, entity, before/after) and that audit logs are readable only by authorized roles with correct tenant scoping.

Maps to: Phase 1 — Foundation

Do not start Step 06 until every required item passes.

Artifacts:

- Markdown: docs/manual-test-guides/step-05-audit.md
- PDF: docs/manual-test-guides/step-05-audit.pdf
- Postman: docs/postman/FMS-API.postman_collection.json (Audit folder)

Prerequisites

- ☐ Steps 01–04 already passing
- ☐ PostgreSQL running; migrations applied (npm run prisma:migrate , includes step05_audit)
- ☐ Super Admin bootstrap env set in server/.env.local
- ☐ At least one company with a company admin (Step 03)
- ☐ A self-registered normal user exists (Step 02 register)

Setup commands

Server:

```
cd finance-management/server
npm install
npx prisma generate
npm run prisma:migrate
npm run dev
```

Client (new terminal):

```
cd finance-management/client
npm install
npm run dev
```

Checklist

A. Audit log API — authorization

#	Test	Expected	Pass?
A1	GET /api/v1/audit/logs as Super Admin	HTTP 200; logs array	[]
A2	Same endpoint as company admin	HTTP 200; only that company's logs	[]
A3	Same endpoint as normal user	HTTP 403 FORBIDDEN	[]

A4	Same endpoint without cookie	HTTP 401	[]
A5	Super Admin with ?tenantId=<id>	HTTP 200; filtered to that tenant	[]

Example:

```
curl -s -b cookies.txt "http://localhost:4000/api/v1/audit/logs?limit=20" | jq
```

B. Audit entries on mutations

Perform each action, then confirm a matching audit row appears (via API or `/audit` UI).

#	Action	Expected audit row	Pass?
B1	Super Admin creates a company	CREATE / Tenant; newValues has name/slug/status; actor = Super Admin	[]
B2	Super Admin toggles company status	UPDATE / Tenant; oldValues + newValues differ on status	[]
B3	Super Admin creates company admin	CREATE / User; newValues has email/role; no password fields	[]
B4	Self-register a new user	CREATE / User; actor = same user	[]

C. Tenant isolation

#	Test	Expected	Pass?
C1	Company admin lists audit logs	No entries for other companies	[]
C2	Super Admin lists all logs	Sees platform + tenant-scoped entries	[]

D. Client audit UI

#	Test	Expected	Pass?
D1	Home as Super Admin	Shows Audit trail link	[]
D2	Home as company admin	Shows Audit trail link	[]
D3	Home as normal user	No audit link	[]
D4	Open <code>/audit</code> as Super Admin	Recent entries render with before/after	[]
D5	Normal user opens <code>/audit</code>	Redirected home	[]

E. Coding rules smoke

#	Test	Expected	Pass?
E1	Audit model + migration	audit_logs table in Prisma schema / DB	[]
E2	Central writer	server/src/services/auditService.ts (writeAuditLog)	[]

E3	Wired into existing mutations	tenant create/update/admin + user register	[]
E4	Sensitive fields stripped	No password / passwordHash in audit JSON	[]
E5	Permission gate	audit:read on GET /audit/logs	[]

Pass criteria for Step 05

- ☐ A1–A5 pass
- ☐ B1–B4 pass
- ☐ C1–C2 pass
- ☐ D1–D5 pass
- ☐ E1–E5 pass

When all required items pass: mark Notion **Build audit logging foundation...** Done, then start **Step 06 — Dynamic fields API**.

Notes / failures

Item	What failed	Fix applied

Printable PDF

[docs/manual-test-guides/step-05-audit.pdf](#)